

Obiettivo della tesi

Valutare lo stato di salute a livello di sicurezza di un'infrastruttura Azure e/o VMware rispetto ai CIS Benchmark.

Progettare e sviluppare un tool di assessment che:

- Legga configurazioni Azure/VMware
- Valuti lo stato dell'infrastruttura rispetto ai CIS Benchmark.
- Produca uno stato di salute misurabile.
- Mappi le remediation suggerite.

Struttura Tesi

Fase di studio degli standard.

Analisi CIS Azure (Azure Foundations versione 5.0.0 del 2025)

Analisi CIS VMware (VMware ESXI 8.0.0 versione 1.3.0 del 2025)

Da qui evidenziare un sottoinsieme di controlli rilevanti, definendo quindi dei confini nell'ambito dell'analisi dello stato.

Fase di modellazione delle metriche

- Definizione dati del singolo controllo, ad esempio:
Id controllo; descrizione; severità; stato(OK/KO)
- Definizione metriche aggregate di valutazione, ad esempio:
percentuale di controlli conformi
percentuale di controlli non conformi
eventuale punteggio complessivo in funzione della severità

Fase di implementazione del tool

caratteristiche del tool:

Lettura configurazione Azure(mediante az cli o altro metodo)

Lettura configurazione VMware(mediante PowerCLI o altro metodo)

Elaborazione dei controlli e generazione report in un formato da decidere(json, csv, etc. etc.)

Fase di analisi dei risultati ottenuti e mappatura remediation

valutazione della compliance media globale.

Quanto lavoro serve per effettuare la remediation suggerita.

Differenze di approccio alla remediation tra cloud e on-premise.

Per ogni controllo non conforme, andare a eseguire mappatura remediation ufficiale(CIS o documentazione vendor).

Classificazione effort remediation(basso/medio/alto)

(andrebbe modellato il concetto di effort, per esempio classificarlo in base a numero di componenti coinvolti, necessità di downtime, impatto architetturale, necessità di skills specialistiche).

Esempi: effort basso(modifica configurazione singolo parametro, no downtime, no dipendenze)

effort medio(modifica di più componenti, possibile riavvio servizio, verifica compatibilità)

effort alto(Redesign parziale architettura, down significativo, impatto su più sistemi)

Di seguito una possibile modellazione del concetto di effort.

Per ogni controllo i , l'effort può essere definito come segue

$$E_i = (w_c \cdot C_i) + (w_d \cdot D_i) + (w_r \cdot R_i)$$

$w_c + w_d + w_r = 1$ pesi da attribuire alle 3 aree dell'effort E

C_i – Complessità strutturale dell'intervento

Misura l'entità dell'intervento richiesto.

Misurata come segue:

- 1 → modifica parametrica
- 2 → modifica configurazione multi-componente
- 3 → modifica che altera l'architettura

D_i – Impatto di indisponibilità

Misura l'entità del downtime come conseguenza dell'intervento richiesto.

- 0 → nessuna interruzione di servizio
- 1 → necessario il riavvio del servizio
- 2 → necessario downtime di sistema durante l'intervento.

R_i – Reversibilità dell'intervento

Misura il costo di un eventuale rollback rispetto all'intervento richiesto.

- 1 → facilmente reversibile (restore parametro)
- 2 → reversibile con procedura strutturata
- 3 → rollback non banale / richiede riconfigurazione complessa

Valore della tesi

Il valore aggiunto della tesi sarà costituito dalla formalizzazione delle metriche, automazione della verifica, modello di scoring del sistema.

Possibile titolo provvisorio per la tesi:

Valutazione della compliance ai CIS Benchmark in ambienti Cloud e on-premise mediante sviluppo di un tool di analisi